

SYNTHETIC - PROOF OF CONCEPT

IT Risk Assessment

Orion Automated Assembly Line - Site Harbor

Northstar Medical Devices (fictional)

Field	Value
ITRA Number	SYN-008
ITRA Version	1.0
Business Application	Orion Automated Assembly Line - Site Harbor
Application ID	NMD-ORA-008
Type	Manufacturing Equipment / IT-OT System
Major Event	Initial synthetic assessment
Description	Local deployment of the standardized Orion Automated Assembly Line. The core equipment architecture is common across all ten fictional locations; this assessment records the implementation choices made at Site Harbor.
State	Approved for synthetic analytics testing
Location	Site Harbor

Confidentiality note

This document is entirely fictional. Names, identifiers, policies, sites, systems and implementation details were invented for an AI analytics proof-of-concept and are not intended to represent any real company environment.

1. Canonical Equipment Architecture

The local deployment uses the standard Orion platform. Approximately 80% of the architecture is fixed; local variation is limited to identity, security operations, support access, backup and other implementation settings.

Component	Purpose / technology	OS	Auth & connectivity	Site variation
Orion PLC Control Pair	Deterministic motion, sequence and interlock control; Industrial PLC pair	Vendor real-time firmware	Local engineering roles; no directory integration; Manufacturing control VLAN; engineering protocol restricted	Identical hardware/firmware baseline; local IP and role configuration
Operator HMI Cluster	Operate the line, acknowledge alarms, review batch status; Industrial touch HMI terminals	Embedded Windows IoT LTSC	Directory-backed where supported; one legacy interface may require local identity; Manufacturing application VLAN	Common image; local identity mapping and session settings
Vision Inspection Station	Inspect assembly attributes and reject nonconforming units; Industrial vision controller + cameras	Vendor Linux appliance	Local application accounts; service integration supported; Inspection VLAN; outbound data to application server	Identical appliance family; local account and retention configuration
Orion Application Server	Coordinate line services, collect events and expose operator services; Virtual Windows application server	Windows Server 2022	Active Directory capable; service identities supported; Manufacturing server VLAN; MES and logging routes	Identical server role; local domain OU and hardening parameters
Orion SQL Server	Store local production history and configuration data; Virtual SQL database server	Windows Server 2022 + SQL Server	Directory groups and service identity; Manufacturing server VLAN; restricted DB flows	Common schema; local backup schedule and service identity configuration
Engineering Workstation	Authorized maintenance, diagnostics and controlled configuration changes; Industrial engineering PC	Windows 11 Enterprise LTSC	Directory-backed named identities; emergency local account possible; Engineering VLAN; controlled management routes	Common build; local privileged-access and remote-support configuration
Barcode and Scanner Set	Read component and unit identifiers during assembly; Ethernet barcode readers	Embedded firmware	Local device administrator only; Device VLAN to application server	Identical model family; local admin password and network settings
MES Interface Service	Exchange orders, confirmations and production status with central MES; Windows integration service	Runs on Orion Application Server	Service identity; mutual TLS application authentication; Outbound to central MES gateway	Common interface contract; local service credentials and endpoint route
Security Logging Connector	Forward supported audit and security events to central SIEM; Windows agent + syslog relay	Windows agent / hardened Linux relay	Managed service identity / certificate; Outbound to central security logging service	Common connector; local source onboarding may vary
Backup Agent and Repository Interface	Protect server configuration and production data; Enterprise backup agent	Windows agent	Managed service identity; Outbound to central backup service	Common tooling; local frequency, retention and restore testing vary
Remote Administration Gateway Path	Provide approved internal or supplier support without direct Internet exposure; Jump-host / brokered remote administration path	Central service; endpoint clients on engineering workstation	Directory identity, MFA where remote access enabled; Brokered management route only	Central pattern; each site chooses whether supplier access is enabled and how tightly it is controlled

2. ITRA Scoping Questions

ID	Question	Answer	Rationale / Comments
B.1	Does the application support a regulated manufacturing process?	Yes	The Orion line executes automated assembly and inspection steps for a fictional regulated disposable device.
B.1.1	Could incorrect system behavior affect product quality?	Yes	Incorrect sequence, recipe or inspection behavior could allow nonconforming units to progress.
B.1.2	Could system failure directly create a patient safety concern?	Potentially	The system does not treat patients, but undetected manufacturing defects could contribute to downstream product risk.
B.2	Could loss of integrity of production data have regulatory impact?	Yes	Production and inspection records support batch disposition and manufacturing traceability.
B.2.1	Is the financial impact of an extended outage material to the local operation?	Yes	A prolonged outage would stop the standardized assembly process and may require manual recovery/reconciliation.
B.3	Is confidentiality a primary security objective for the system?	Low	The system mainly handles manufacturing configuration and production identifiers rather than business-confidential research data.
B.3.1	Is integrity a primary security objective?	High	Unauthorized configuration or record modification could affect product and production decisions.
B.3.2	Is availability a primary security objective?	High	Loss of line-control, server or interface services can interrupt production.
B.4	How many regular interactive users are expected?	20-45	Operators, engineering, maintenance and quality support use the system depending on shift model.
B.4.1	Does the system intentionally process personal data?	Limited	Named user IDs and audit records may identify employees; the process does not require customer or patient information.
B.5	What is the information classification?	Internal - Manufacturing	Production records and configuration are for internal operational use.
B.5.1	Does the system create or store regulated production records?	Yes	Local records include assembly events, inspection results, configuration history and transfer status.

3. Technical Assessment

ID	Question	Answer	Comments
T.1	Software category	Industrial control and manufacturing application	PLC/HMI control with local server, database, vision and enterprise integrations.
T.2	Customization level	Configured standard platform	Common Orion baseline with approved site-specific configuration; no site-specific redesign of the core equipment.
T.3	External suppliers	Yes	Fictional equipment supplier supports hardware and industrial software; access model is site-specific.
T.4	AI or machine-learning components	No	Vision inspection uses deterministic vendor algorithms; no AI/ML decision component is in scope for this synthetic assessment.
T.5	Hosting model	On-premise manufacturing environment	Local industrial devices plus virtual Windows servers in the site manufacturing infrastructure.
T.6	Central integrations	MES, identity, security logging, backup	Standard enterprise integration pattern used wherever the component supports it.
T.7	Operating environment	Segregated manufacturing network	Separate control, device, server and engineering zones with restricted enterprise routes.
T.8	Data transfer	Automated	Production events and confirmations are transferred automatically to the central MES gateway.

4. IT Security Assessment

ID	Question	Answer	Comments
S.1	Is the equipment connected to a segregated manufacturing network?	Yes	See NW.1.1 for local segmentation details.
S.2	Are workforce identities centrally managed where technically supported?	Yes	Windows and supported HMI access use the enterprise directory; industrial exceptions are documented in controls.
S.3	Are patches managed through a controlled process?	Yes	Mix of central Windows patching and qualified industrial maintenance depending on component.
S.4	Are security logs centrally collected?	No	See logging controls for exact source coverage.
S.5	Is remote administration permitted?	Yes	Only approved brokered support patterns are intended; local enablement differs.
S.6	Is privileged access required?	Yes	Engineering and server administration require elevated capability at every location.
S.7	Are shared interactive accounts used?	Yes	The answer depends on local HMI/maintenance implementation and may require reading multiple control responses.
S.8	Are service identities used?	Yes	Integration and backup components may use non-personal identities depending on site configuration.
S.9	Does any Orion component have direct Internet connectivity?	No	No direct browsing or inbound Internet exposure is required for normal operation.
S.10	Can supplier personnel access the system remotely?	Restricted	Where permitted, access must use the approved brokered support route and local authorization.

5. Security Threat Scenarios

Gross likelihood reflects the standard Orion platform before local control effectiveness. Net risk is addressed in Section 7.

ID	Threat	Gross likelihood	Rationale
TH.1	Unauthorized access to operator or engineering functions	Possible (10-25%)	The platform has multiple interactive and administrative interfaces; gross likelihood is assessed before local control effectiveness.
TH.2	Malicious software on Windows server or engineering workstation	Possible (10-25%)	General-purpose Windows components and maintenance tooling create a plausible malware path.
TH.3	Insider misuse of privileged access	Unlikely (<10%)	Privileged access is limited to a small support population but could affect production configuration.
TH.4	Software or configuration error	Likely (25-50%)	Complex PLC/HMI/server integration and maintenance changes can introduce configuration defects.
TH.5	User error during operation or maintenance	Likely (25-50%)	Operators and engineers interact with alarms, recipes, diagnostics and recovery actions.
TH.6	Hardware or industrial device failure	Possible (10-25%)	Controllers, vision equipment, storage and network components can fail despite redundancy and maintenance.
TH.7	Supplier support channel compromise	Unlikely (<10%)	Supplier access is not continuously open but support channels can introduce credential and session risk where enabled.

6. ITRA Controls

Control requirements are common across sites. Detailed descriptions below capture the local implementation and may contain the evidence required for later normalization.

AC.1.1	Interactive users must be uniquely attributable wherever technically feasible.
Status	Compliant
Type	Risk Control
Detailed Description	Named directory IDs are the norm, but not every interactive path can tie activity to one person; exceptions are described under shared-identity controls.
Implementation Considerations	Review local application exceptions rather than assuming directory membership covers every interactive interface.

AC.1.2	Supported Orion components must use the approved enterprise directory for workforce authentication.
Status	Compliant
Type	Risk Control
Detailed Description	Windows servers, the engineering workstation and supported HMIs are joined to the Northstar Enterprise Directory. PLC and appliance firmware remain outside directory scope by design.
Implementation Considerations	Embedded devices without directory support require local role governance.

AC.1.3	Access must be provisioned through an authorized request and role assignment process.
Status	Compliant
Type	Lifecycle Requirement
Detailed Description	Access requests identify the requested Orion role and are approved by the line owner before directory-group or local-role assignment. Leavers are removed through the standard workforce offboarding feed plus site verification.
Implementation Considerations	Ensure urgent maintenance access is retrospectively documented when emergency work is necessary.

AC.1.4	Access to the Orion platform must be periodically reviewed by an accountable system owner.
Status	Partially Compliant
Type	Risk Control
Detailed Description	Access is checked when staff change role or when an issue is raised. A recurring calendar review was discussed but evidence of a completed scheduled review was not provided.
Implementation Considerations	Retain evidence of the review, not only the current user listing.

AC.2.1	Shared interactive identities may only be used where justified and must have compensating controls.
Status	Partially Compliant
Type	Risk Control
Detailed Description	Two local logins are shared by the maintenance team: one HMI operator account and one engineering account. Supervisors control who may use the workstation, but the application itself does not record the individual person.
Implementation Considerations	Document whether the exception is technically necessary or chosen for convenience.

AC.2.2	Credentials for shared interactive identities must be protected, rotated and access-controlled.
Status	Partially Compliant
Type	Risk Control

Detailed Description	The shared password is maintained by the local automation support lead in the restricted site support record and changed when team membership changes. No enterprise password safe is used for this credential.
Implementation Considerations	Credential access should be attributable even when the downstream application identity is shared.

AC.2.3	Non-personal service identities must be limited to automated functions and documented.
Status	Compliant
Type	Risk Control
Detailed Description	The MES connector runs with local account ORA_IFACE. Ownership is understood by the automation team, but the current support note does not identify a formal credential custodian or rotation interval.
Implementation Considerations	Deny interactive sign-in and assign a clear owner for every service identity.

AC.2.4	Privileged administration must use controlled administrative identities or equivalent safeguards.
Status	Compliant
Type	Risk Control
Detailed Description	Local Administrator is used by the automation support team for some engineering tasks. The password is known to a small support group and is changed when staff leave.
Implementation Considerations	Separate routine and elevated activity where the platform supports it.

AC.2.5	Privileged credentials must be centrally governed or otherwise strongly controlled.
Status	Partially Compliant
Type	Risk Control
Detailed Description	Privileged local passwords are controlled by the site automation support group. There is no central checkout workflow for the local administrator credential.
Implementation Considerations	Emergency local credentials need rotation, custody and evidence of controlled use.

AC.3.1	Remote administrative access must use an approved brokered path and strong authentication.
Status	Compliant
Type	Risk Control
Detailed Description	Remote administration is enabled through the Northstar Remote Support Gateway. Access is brokered; endpoints are not reachable directly from office or external networks.
Implementation Considerations	Remote routes should be disabled when not needed and should never expose endpoints directly.

AC.3.2	Remote administrative access must use multi-factor authentication when applicable.
Status	Partially Compliant
Type	Risk Control
Detailed Description	The gateway requires a directory password and a one-time emailed access code to a shared site support mailbox. The site considers this a second step, but it is not bound to the individual administrator.
Implementation Considerations	The second factor must be bound to the individual identity, not a shared mailbox or team device.

6. ITRA Controls (continued)

NW.1.1	The Orion platform must be placed on a segregated manufacturing network with restricted routing.
Status	Partially Compliant
Type	Risk Control
Detailed Description	The servers and PLCs sit on manufacturing VLANs, but the engineering workstation shares a broader site maintenance segment. Firewall cleanup is listed for the next network change window.
Implementation Considerations	Validate actual firewall zoning against the documented manufacturing architecture.
NW.1.2	Inbound and outbound flows must be limited to documented business and support requirements.
Status	Compliant
Type	Risk Control
Detailed Description	The servers and PLCs sit on manufacturing VLANs, but the engineering workstation shares a broader site maintenance segment. Firewall cleanup is listed for the next network change window.
Implementation Considerations	Remove temporary vendor or commissioning flows after qualification.
NW.1.3	Direct Internet connectivity from Orion components must not be permitted.
Status	Compliant
Type	Risk Control
Detailed Description	No Orion endpoint has direct Internet routing. Update packages and supplier sessions enter through controlled enterprise services rather than direct outbound browsing from the equipment.
Implementation Considerations	Do not use direct web browsing from engineering endpoints to retrieve patches.
LG.1.1	Security-relevant events from supported Orion components must be forwarded to central monitoring.
Status	Not Compliant
Type	Risk Control
Detailed Description	Only Windows server operating-system events are currently sent to central monitoring. HMI, engineering workstation application activity and remote-support session details are retained locally, and routine central review is not established.
Implementation Considerations	Track source coverage; a healthy collector does not prove every subsystem is forwarding.
LG.1.2	Components unable to forward events centrally must retain sufficient local audit information.
Status	Compliant
Type	Risk Control
Detailed Description	Local event history exists on some components but retention and review intervals are not consistently configured.
Implementation Considerations	Define retention and review expectations for logs that remain local.
LG.1.3	System time must be synchronized to an approved enterprise time source where supported.
Status	Compliant
Type	Risk Control
Detailed Description	Servers use the enterprise time source; two embedded devices use their internal clocks and are checked during maintenance.

Implementation Considerations	Time drift can hinder event correlation across PLC, HMI, server and gateway records.
-------------------------------	--

VM.1.1	Supported server and workstation components must receive security patches through a controlled process.
Status	Partially Compliant
Type	Risk Control
Detailed Description	The application server is included in central patching, but engineering workstation and HMI updates are performed manually when operations can release the line. No fixed maximum delay is documented.
Implementation Considerations	Coordinate deployment with production windows but maintain a maximum tolerated deferral.

VM.1.2	Industrial components requiring vendor validation must have a documented local patch process.
Status	Partially Compliant
Type	Risk Control
Detailed Description	The application server is included in central patching, but engineering workstation and HMI updates are performed manually when operations can release the line. No fixed maximum delay is documented.
Implementation Considerations	Supplier validation should not become an indefinite reason for deferral.

VM.1.3	The Orion environment must be included in vulnerability identification activities where technically safe.
Status	Partially Compliant
Type	Risk Control
Detailed Description	The Windows server is scanned, but embedded devices are excluded from active scanning. Site staff review supplier advisories manually; evidence is maintained inconsistently.
Implementation Considerations	Use non-intrusive methods for fragile industrial devices.

VM.1.4	Malware protection must be enabled on supported general-purpose operating systems.
Status	Compliant
Type	Risk Control
Detailed Description	Enterprise anti-malware is active on Windows servers and the engineering workstation; PLCs and embedded appliances are outside product scope.
Implementation Considerations	Exclude unsupported embedded appliances only with documented rationale.

VM.1.5	Application execution restrictions should be used on engineering endpoints where compatible.
Status	Not Compliant
Type	Risk Control
Detailed Description	No application allow-list is configured on the engineering workstation; standard anti-malware and local software-install procedure are relied upon.
Implementation Considerations	Vendor diagnostics may need narrowly scoped allow rules.

6. ITRA Controls (continued)

BC.1.1	Critical Orion server data and configuration must be backed up at an approved frequency.
Status	Partially Compliant
Type	Risk Control
Detailed Description	Nightly SQL export is copied to the site file service, but full server image backup is not yet onboarded to the enterprise backup platform. Configuration exports are created before major changes.
Implementation Considerations	Include databases, configuration exports and interface certificates/secrets as appropriate.
BC.1.2	Backup restoration must be periodically tested and evidence retained.
Status	Partially Compliant
Type	Lifecycle Requirement
Detailed Description	Backup jobs are reported as successful. The team could not locate evidence of a recent end-to-end restore exercise.
Implementation Considerations	A successful backup job is not equivalent to demonstrated restoration.
BC.2.1	A recovery plan must define restoration of Orion services following a disruptive event.
Status	Partially Compliant
Type	Lifecycle Requirement
Detailed Description	A recovery runbook is being drafted. Current recovery depends on vendor installation media, local configuration exports and the site support team; target recovery sequencing is still TBD. Owner / approval date: TBD.
Implementation Considerations	Document dependencies on central MES, identity, networking and supplier installation media.
BC.2.2	Recovery procedures must be exercised periodically or during an equivalent controlled test.
Status	Partially Compliant
Type	Lifecycle Requirement
Detailed Description	No full recovery exercise has been completed; selected configuration restoration steps were discussed during the assessment.
Implementation Considerations	Exercise both technical restore steps and decision/escalation responsibilities.
TP.1.1	Supplier support access must be explicitly approved, time-bounded and attributable.
Status	Partially Compliant
Type	Risk Control
Detailed Description	The equipment supplier may connect when the line is down and local support requests help. Access is approved by the shift engineering lead; session recording is not consistently enabled.
Implementation Considerations	Supplier identity, approval, time limit and business reason should be independently visible.
TP.1.2	Supplier remote sessions must use the approved remote administration path when enabled.
Status	Partially Compliant
Type	Risk Control
Detailed Description	The equipment supplier may connect when the line is down and local support requests help. Access is approved by the shift engineering lead; session recording is not consistently enabled.
Implementation Considerations	Avoid unmanaged conferencing tools as a substitute for the approved support path.

DI.1.1	Production records transferred from Orion to central systems must be protected from unauthorized modification.
Status	Compliant
Type	Risk Control
Detailed Description	MES messages use mutually authenticated TLS through the central gateway. The interface service validates message structure and records transfer errors in the local application log.
Implementation Considerations	Keep transport protection and application validation in scope.
DI.1.2	Configuration changes affecting production must be authorized and traceable.
Status	Compliant
Type	Lifecycle Requirement
Detailed Description	PLC, HMI and application changes are linked to an approved site change record. Engineering project versions are retained and a second engineer verifies production-impacting parameter changes during qualification.
Implementation Considerations	Retain traceability from approved change through deployed configuration version.
PD.1.1	Removable media use on Orion components must be restricted and controlled.
Status	Partially Compliant
Type	Risk Control
Detailed Description	Removable media is discouraged and requires supervisor approval. The engineering workstation can still read standard USB media for vendor packages; scanning is procedural rather than technically enforced.
Implementation Considerations	Vendor update needs should not create an unmonitored USB exception.
PD.1.2	Physical access to Orion control and engineering components must be restricted to authorized personnel.
Status	Compliant
Type	Risk Control
Detailed Description	Production access is badge-controlled, but the engineering workstation is accessible to the wider maintenance team during staffed hours.
Implementation Considerations	Physical restriction is an important compensating control for industrial interfaces that cannot identify individual users.

7. ITRA Risks

Gross ratings are intentionally similar across locations because the platform and intended function are the same. Net likelihood reflects local implementation differences. Gross Risk and Net Risk are simple impact x likelihood scores for this synthetic dataset.

Risk ID	Name	Gross impact	Gross likelihood	Gross risk	Net impact	Net likelihood	Net risk	Comments
R.1	Unauthorized production access	4 - Critical	2 - Possible	8	4 - Critical	3 - Likely	12	Named access, review cadence and treatment of shared identities drive the residual exposure.
R.2	Unauthorized engineering change	4 - Critical	2 - Possible	8	4 - Critical	3 - Likely	12	Controlled privileged identities and traceable configuration change reduce the chance of unauthorized engineering modification.
R.3	Malware disruption	3 - Major	2 - Possible	6	3 - Major	3 - Likely	9	Anti-malware is standard; application control and removable-media restrictions vary by site.
R.4	Loss of production data integrity	4 - Critical	2 - Possible	8	4 - Critical	2 - Possible	8	Residual likelihood is reduced by the standard Orion control baseline and the site implementation described in the referenced control domains.
R.5	Loss of production availability	3 - Major	3 - Likely	9	3 - Major	2 - Possible	6	Residual likelihood is reduced by the standard Orion control baseline and the site implementation described in the referenced control domains.
R.6	Undetected security activity	3 - Major	2 - Possible	6	3 - Major	3 - Likely	9	Central event coverage is the main differentiator; local-only logs provide weaker detection and correlation.
R.7	Delayed remediation of vulnerabilities	3 - Major	3 - Likely	9	3 - Major	3 - Likely	9	Residual risk increases where vendor qualification or local maintenance causes patch or vulnerability-management delay.
R.8	Compromise through supplier support	3 - Major	2 - Possible	6	3 - Major	3 - Likely	9	Supplier access is only relevant where enabled; named MFA sessions and recording reduce residual likelihood.
R.9	Backup restoration failure	3 - Major	2 - Possible	6	3 - Major	3 - Likely	9	Successful backup completion is not treated as proof of recoverability without restoration evidence.
R.10	Inadequate disaster recovery	3 - Major	2 - Possible	6	3 - Major	3 - Likely	9	The maturity and testing of the recovery runbook determine residual recovery risk.
R.11	Removable media introduction of malware	3 - Major	2 - Possible	6	3 - Major	2 - Possible	6	Residual likelihood is reduced by the standard Orion control baseline and the site implementation described in the referenced control domains.
R.12	Misuse of shared or privileged credentials	4 - Critical	2 - Possible	8	4 - Critical	3 - Likely	12	Shared-credential custody, privileged-account governance and compensating physical controls affect accountability.

Appendix A - Local Implementation Notes

The notes below are assessment working context. They intentionally use local phrasing rather than normalized analytics labels.

Identity and administration

Named directory IDs are the norm, but not every interactive path can tie activity to one person; exceptions are described under shared-identity controls. Local Administrator is used by the automation support team for some engineering tasks. The password is known to a small support group and is changed when staff leave.

Support model

Remote administration is enabled through the Northstar Remote Support Gateway. Access is brokered; endpoints are not reachable directly from office or external networks. The equipment supplier may connect when the line is down and local support requests help. Access is approved by the shift engineering lead; session recording is not consistently enabled.

Monitoring

Only Windows server operating-system events are currently sent to central monitoring. HMI, engineering workstation application activity and remote-support session details are retained locally, and routine central review is not established. Local event history exists on some components but retention and review intervals are not consistently configured.

Maintenance

The application server is included in central patching, but engineering workstation and HMI updates are performed manually when operations can release the line. No fixed maximum delay is documented. The Windows server is scanned, but embedded devices are excluded from active scanning. Site staff review supplier advisories manually; evidence is maintained inconsistently.

Recovery

Nightly SQL export is copied to the site file service, but full server image backup is not yet onboarded to the enterprise backup platform. Configuration exports are created before major changes. Backup jobs are reported as successful. The team could not locate evidence of a recent end-to-end restore exercise. A recovery runbook is being drafted. Current recovery depends on vendor installation media, local configuration exports and the site support team; target recovery sequencing is still TBD.

Physical / media

Removable media is discouraged and requires supervisor approval. The engineering workstation can still read standard USB media for vendor packages; scanning is procedural rather than technically enforced. Production access is badge-controlled, but the engineering workstation is accessible to the wider maintenance team during staffed hours.

Assessment statement

This synthetic ITRA represents the Orion deployment at Site Harbor only. Local implementation choices should be interpreted together across scoping, technical, security, control and risk sections rather than from a single answer in isolation.